[LAW FIRM NAME]

INTERNAL CONTROL & RISK MANAGEMENT FRAMEWORK

COSO ERM · ISO 27001 · NIST RMF · Ghana Regulatory Compliance

---

Document Reference: ICRMF-001 | Version: 1.0 | Classification: Confidential — Internal

Primary Framework: COSO ERM 2017 | ISO 27001:2022 | NIST RMF | Ghana DPA 2012 | COSO Internal Control 2013

CONFIDENTIAL — NOT FOR PUBLIC DISTRIBUTION

1. Document Control

Field	Details
Document Title	Internal Control & Risk Management Framework
Document Reference	ICRMF-001
Version	1.0
Status	Approved
Effective Date	2025
Owner	Managing Partner
Review Frequency	Annual or upon material organisational change
Applicable Frameworks	COSO ERM 2017 | COSO IC 2013 | ISO 27001:2022 | NIST RMF | Ghana DPA 2012 | BoG Third-Party Standards

2. Executive Summary

This Internal Control and Risk Management Framework ('the Framework') establishes [Law Firm Name]'s structured approach to identifying, assessing, managing, and monitoring risks that could affect the achievement of the Firm's professional, operational, financial, and compliance objectives.

The Framework is designed to satisfy the internal control and enterprise risk management expectations of third-party reviewers including financial institutions conducting vendor due diligence, regulatory bodies, and auditors. It is built upon the Committee of Sponsoring Organizations of the Treadway Commission (COSO) Enterprise Risk Management Framework 2017 and the COSO Internal Control — Integrated Framework 2013, augmented by ISO 27001:2022 and NIST Risk Management Framework for information security risks.

Third-Party Due Diligence Note

This Framework has been prepared to meet the internal control and risk management documentation requirements of regulated financial institutions and their external advisors conducting third-party due diligence on professional service providers. It demonstrates the Firm's governance maturity and readiness for audit.

3. Framework Architecture: COSO ERM 2017

COSO Enterprise Risk Management — Integrating with Strategy and Performance (2017)

The COSO ERM Framework organises risk management across five interrelated components, twenty principles, and three objectives categories. [Law Firm Name] has adopted this architecture as the primary governance structure for enterprise risk management.

COSO Component	Principles Addressed	Firm Implementation
Governance & Culture	Principles 1–5: Board oversight, operating structures, culture, talent	Partner-level oversight; defined roles; ethics and conduct standards
Strategy & Objective-Setting	Principles 6–10: Business context, risk appetite, strategy, objectives	Annual strategy review; documented risk appetite statement
Performance	Principles 11–16: Risk identification, severity, prioritisation, response	Risk Register maintained; quarterly review cycle
Review & Revision	Principles 17–19: Substantial change assessment, ongoing review	Annual framework review; post-incident review process
Information, Communication & Reporting	Principles 20	Board risk reporting; staff risk communication; third-party disclosures

4. COSO Internal Control — Integrated Framework 2013

COSO Internal Control — Integrated Framework 2013 (Five Components, Seventeen Principles)

For operational and financial controls, the Firm applies the COSO Internal Control — Integrated Framework 2013. This ensures that internal controls are appropriately designed, implemented, and maintained across five components:

Component	Objective	Key Controls at [Law Firm Name]
Control Environment	Foundation for the entire internal control system	Tone at the top; partner commitment; ethics policy; staff accountability
Risk Assessment	Process for identifying and analysing risks	Annual risk assessment; updated Risk Register; new matter risk screening
Control Activities	Policies and procedures ensuring risk responses are effective	Access controls; segregation of duties; authorisation limits; document controls
Information & Communication	Relevant information identified and communicated	Monthly management reporting; staff briefings; client communication protocols
Monitoring Activities	Ongoing and separate evaluations of internal control performance	Annual internal review; incident post-mortems; external audit as applicable

5. Risk Governance Structure

5.1 Risk Appetite Statement

[Law Firm Name] maintains a low to moderate risk appetite across all operational and compliance risk categories. The Firm has zero tolerance for:

- Breaches of client confidentiality or legal professional privilege
- Non-compliance with the Ghana Data Protection Act 2012 or other applicable legislation
- Failure to maintain professional indemnity and required regulatory standing
- Information security incidents resulting from failure to apply documented controls

The Firm accepts moderate risk in areas of business development, technology investment, and market expansion where the potential benefit is proportionate and risks are managed.

5.2 Risk Governance Roles

Role	Risk Responsibility	Reporting
Managing Partner	Ultimate risk owner; approves Risk Appetite Statement; receives board-level risk reports	Self-reporting
Partners / Senior Associates	Risk owners for practice area risks; escalate emerging risks	To Managing Partner
Designated IT / Compliance Lead	Operational risk management; Risk Register maintenance; compliance monitoring	To Managing Partner
All Staff	Day-to-day control compliance; incident reporting	To Line Manager / IT Lead

6. Risk Assessment Methodology

ISO 31000:2018 | NIST SP 800-30 | COSO Performance Component Principles 11–13

6.1 Risk Identification

Risks are identified through the following mechanisms:

- Annual comprehensive risk assessment workshop (partners and IT Lead)
- Ongoing operational monitoring and staff-reported incidents
- Regulatory and legal landscape scanning (quarterly)
- Post-incident reviews and lessons learned
- Client feedback and matter risk assessments

6.2 Risk Scoring Matrix

Each identified risk is assessed using a 5x5 likelihood-impact matrix:

Rating	Likelihood	Impact
5 — Critical	Almost certain: likely to occur within 12 months	Catastrophic: regulatory action, loss of practising certificate, major financial loss
4 — High	Likely: strong probability of occurrence	Major: significant financial loss,

Rating	Likelihood	Impact
		reputational damage, data breach notification
3 — Medium	Possible: could occur under certain conditions	Moderate: operational disruption, client complaint, regulatory inquiry
2 — Low	Unlikely: not expected to occur	Minor: limited impact; manageable through routine operations
1 — Minimal	Rare: only in exceptional circumstances	Negligible: no significant impact on operations or clients

Risk Score = Likelihood x Impact. Scores of 15–25 are Critical; 10–14 are High; 5–9 are Medium; 1–4 are Low.

7. Risk Register

COSO Performance Component | ISO 27001:2022 Clause 6.1 | NIST RMF Step 2

The Firm maintains a current Risk Register covering the following risk domains. The register is reviewed quarterly and updated following any material change or incident.

Risk Domain	Example Risks	Primary Control Measures
Information Security	Cyber attack, data breach, ransomware, phishing	ISO 27001-aligned ISP; MFA; antivirus; staff training; incident response plan
Data Protection & Privacy	DPA non-compliance, unauthorised data disclosure, retention failure	DPC registration; PDP Policy; data retention schedule; training
Legal & Regulatory Compliance	Regulatory change, non-compliance with professional obligations	Regulatory change monitoring; external counsel; annual compliance review
Client Confidentiality	Inadvertent disclosure, insider threat, physical document exposure	Clean desk policy; access controls; confidentiality agreements; secure disposal
Operational / Technology	System failure, data loss, software vulnerability	BCP/DRP; Microsoft 365 backup; patch management; antivirus
Third-Party / Vendor	Cloud service outage, vendor data breach, supplier failure	Vendor risk assessment; DPAs; contractual security obligations
Financial	Fee recovery failure, fraud, financial misstatement	Segregation of duties; authorisation controls; financial review procedures
Reputational	Professional misconduct, negative publicity, client dissatisfaction	Complaints handling; professional indemnity; conduct standards

8. Control Activities

COSO IC 2013 Control Activities Component | ISO 27001:2022 Annex A | NIST CSF PR

8.1 Preventive Controls

- Access control and user authentication (MFA on all Microsoft 365 accounts)
- Least privilege principle applied to all system access
- Staff data protection and security awareness training
- Contractual confidentiality obligations for all employees and third parties
- New matter risk assessment on client engagement

8.2 Detective Controls

- Microsoft 365 audit logging and activity monitoring
- Antivirus and endpoint detection with real-time alerting
- Periodic access rights reviews (at least annual)
- Incident reporting mechanism available to all staff
- Annual internal risk and compliance review

8.3 Corrective Controls

- Documented Incident Response Plan (incorporated in ISP-001)
- Data breach notification procedures (incorporated in PDP-001)
- Disaster Recovery and Business Continuity Plan (DRBCP-001)
- Post-incident root cause analysis and corrective action tracking
- Policy review and update procedures following identified control failure

9. Information Security Risk Management

ISO 27001:2022 Clauses 6.1–6.2 | NIST RMF Steps 1–6 | COSO Performance Component

Information security risks are managed in accordance with ISO 27001:2022 and the NIST Risk Management Framework (RMF). The six-step NIST RMF process is applied as follows:

NIST RMF Step	Description	Firm Implementation
1. Categorise	Categorise information systems based on impact	Systems categorised by data sensitivity and business criticality
2. Select	Select baseline security controls	ISO 27001 Annex A controls selected and mapped to Firm environment
3. Implement	Implement the selected controls	Controls implemented per ISP-001 and documented in Statement of Applicability
4. Assess	Assess whether controls are implemented correctly and effective	Annual internal assessment; control testing

NIST RMF Step	Description	Firm Implementation
5. Authorise	Senior management authorises operation of information systems	Managing Partner authorises ISMS scope and control set
6. Monitor	Continuously monitor controls and risk posture	Quarterly risk reviews; ongoing incident monitoring; annual audit

10. Compliance Risk Management

Ghana DPA 2012 | Ghana Cybersecurity Act 2020 | COSO Governance & Culture | ISO 27001 Clause 4.2

The Firm maintains a Compliance Obligations Register covering all applicable legal, regulatory, and professional obligations. Key compliance areas include:

Compliance Area	Obligation Source	Management Mechanism
Data Protection	Ghana DPA 2012 (Act 843)	DPC registration; PDP Policy; DPO appointment; annual review
Cybersecurity	Ghana Cybersecurity Act 2020 (Act 1038)	ISP; incident response plan; staff training
Anti-Money Laundering	AML Act 2008 (Act 749); FATF	KYC/AML client screening; transaction monitoring where applicable
Professional Conduct	Ghana Bar Association; Legal Professions Act	CPD compliance; ethics training; indemnity insurance
Financial Reporting	Companies Act 2019 (Act 992)	Annual accounts; financial controls; auditor engagement
Employment	Labour Act 2003 (Act 651)	Employment contracts; HR policies; health and safety

11. Monitoring, Review, and Reporting

COSO Review & Revision Component | ISO 27001:2022 Clause 9 | NIST RMF Step 6

Activity	Frequency	Output / Audience
Risk Register Review	Quarterly	Updated Risk Register; Managing Partner briefing
Control Effectiveness Assessment	Annual	Internal audit report; corrective action plan
Information Security Review	Annual	ISMS performance report; policy update recommendations
Compliance Obligations Scan	Quarterly	Updated Compliance Register; alerts to

Activity	Frequency	Output / Audience
		Managing Partner
Staff Security Awareness Training	Annual (induction + refresh)	Training completion report
Business Continuity Test	Annual	BCP test report; lessons learned log
Third-Party Risk Review	Annual (on contract renewal)	Vendor risk assessment report
Post-Incident Review	Following each significant incident	Root cause analysis; corrective action log

12. Framework Maintenance

This Framework is owned by the Managing Partner and is maintained by the Designated IT / Compliance Lead. It shall be reviewed:

- Annually as part of the Firm's governance calendar
- Following any significant security incident or data breach
- Upon material change to the Firm's structure, systems, or service scope
- Following significant regulatory or legislative change

All revisions are subject to Managing Partner approval and are recorded in the document version history.

13. Review and Approval

Field	Details
Framework Owner	Managing Partner
Approved By	Managing Partner
Date of Approval	_____
Next Review Date	_____ (12 months from approval)
Version History	v1.0 — Initial issue

Framework Alignment Summary

This Framework is aligned to: COSO Enterprise Risk Management Framework 2017 (all five components and twenty principles); COSO Internal Control — Integrated Framework 2013 (all five components and seventeen principles); ISO 27001:2022 Clause 6.1 (Information Security Risk Management) and Clause 9 (Performance Evaluation); NIST Risk Management Framework (all six steps); ISO 31000:2018 (Risk Management Principles and Guidelines); Ghana Data

Protection Act 2012 (Act 843) — accountability and security obligations; Ghana Cybersecurity Act 2020 (Act 1038) — organisational cybersecurity governance.